

Rencana Pengujian Keamanan Sistem Lost and Found IPB University

1. TESTING

Pengujian keamanan dilakukan menggunakan pendekatan berbasis risiko untuk memitigasi ancaman utama yang telah diprioritaskan melalui *threat modeling* STRIDE. Berdasarkan analisis risiko terbaru, sistem memprioritaskan mitigasi terhadap ancaman kritis berikut:

Prioritas	Ancaman (STRIDE)	Komponen Terancam	Probabilitas	Dampak	Level Risiko
1	SQL Injection	Database Sistem	Sedang	Sangat Tinggi	Sangat Tinggi
2	Session Hijacking	Session Login	Sedang	Tinggi	Tinggi
3	XSS Injection	Form Input	Tinggi	Sedang	Sedang
4	Insider Threat	Data Sensitif	Rendah	Tinggi	Sedang

1.1 Jenis Pengujian

Untuk menguji efektivitas kontrol keamanan terhadap ancaman di atas, metode pengujian dibagi menjadi beberapa kategori:

- **Unit Testing:** Menguji fungsi kriptografi terisolasi (hashing bcrypt, enkripsi AES-GCM), validasi input form, dan integritas prepared statements menggunakan PyTest/unittest.
- **Integration & Security Testing:** Memvalidasi alur AAA secara end-to-end, pemisahan kontrol akses RBAC, penanganan kedaluwarsa sesi, pencegahan bypass URL, serta pengujian injeksi otomatis menggunakan SQLMap dan skrip kustom.
- **Performance Testing (Analisis Kinerja):** Mengukur dampak dari penambahan lapisan keamanan (overhead) menggunakan Apache JMeter dengan beban 100 pengguna simultan (concurrent users) dan 10 iterasi.

2. MATRIKS SKENARIO AUTHENTICATION

Matriks pengujian autentikasi disesuaikan menjadi 6 skenario utama guna memastikan kecocokan mutlak dengan evaluasi fungsional komponen autentikasi sistem:

ID Skenario	Skenario Uji	Input Data	Hasil yang Diharapkan	Mitigasi STRIDE Terkait
AUTH-01	Login valid	Username & password benar	Login berhasil; session token diterbitkan dengan aman.	Spoofing Identity
AUTH-02	Password salah	Username benar, password salah	Login ditolak; sistem memberikan pesan error generik demi keamanan.	Brute Force / Spoofing
AUTH-03	Username tidak terdaftar	Username tidak ada di database	Login ditolak; mencegah enumerasi akun pengguna.	User Enumeration
AUTH-04	Session expired	Token / session cookie kedaluwarsa	Sistem secara otomatis melakukan logout dan mengarahkan ke halaman login.	Session Hijacking (Tinggi)
AUTH-05	Transmisi HTTP	Akses endpoint via non-HTTPS (HTTP plain)	Sistem secara otomatis mengalihkan (redirect) seluruh trafik ke HTTPS.	Information Disclosure (Sniffing)
AUTH-06	Password hashing	Inspeksi database langsung	Password wajib tersimpan dalam bentuk hash bcrypt dengan salt acak, bukan plaintext.	Information Disclosure / Insider Threat

3. MATRIKS SKENARIO AUTHORIZATION

Pengujian otorisasi memastikan sistem Role-Based Access Control (RBAC) membatasi hak akses secara ketat berdasarkan peran pengguna:

ID Skenario	Skenario Uji / Tindakan	Peran Penguji	Hasil yang Diharapkan	Mitigasi STRIDE Terkait
AUTHZ-01	Akses halaman admin	User (Mahasiswa)	Akses DITOLAK (HTTP 403)	Elevation of Privilege

ID Skenario	Skenario Uji / Tindakan	Peran Penguji	Hasil yang Diharapkan	Mitigasi STRIDE Terkait
	(/admin/dashboard)		Forbidden).	
AUTHZ-02	Verifikasi laporan / mengubah tiket	Admin	Akses DIIZINKAN; operasi berjalan sukses.	Otorisasi RBAC Valid
AUTHZ-03	Akses laporan milik orang lain	User A	Akses DITOLAK (HTTP 403 Forbidden) saat mencoba membaca data User B.	Information Disclosure
AUTHZ-04	Modifikasi status tiket langsung via URL	User (Mahasiswa)	Akses DITOLAK (HTTP 403 Forbidden); server menolak manipulasi parameter URL.	Tampering / Elevation of Privilege

4. MATRIKS SKENARIO ACCOUNTING (AUDIT TRAIL)

Skenario ini memvalidasi kelengkapan pencatatan log aktivitas penting untuk kebutuhan investigasi forensik digital:

ID Skenario	Aktivitas yang Diuji	Informasi Minimal yang Wajib Tercatat	Sifat Penyimpanan Log
ACC-01	Login berhasil	ID pengguna, stempel waktu (timestamp), dan IP address pengeksesksi.	Append-Only (No Update/Delete)
ACC-02	Pembuatan tiket	ID pengguna, ID tiket yang dibuat, dan stempel waktu.	Append-Only (No Update/Delete)
ACC-03	Verifikasi tiket oleh admin	ID admin, ID tiket, status lama, status baru, dan stempel waktu.	Append-Only (No Update/Delete)
ACC-04	Akses data sensitif	ID pengguna/admin,	Append-Only (No

ID Skenario	Aktivitas yang Diuji	Informasi Minimal yang Wajib Tercatat	Sifat Penyimpanan Log
	(Dekripsi Data)	jenis data yang diakses, dan stempel waktu.	Update/Delete)

5. RENCANA PENGUJIAN KINERJA (PERFORMANCE TESTING PLAN)

Untuk menjamin bahwa implementasi lapisan keamanan (AAA, enkripsi AES-GCM, hashing bcrypt) tidak mendegradasi performa aplikasi secara ekstrem, dilakukan pengujian beban dengan parameter operasional sebagai berikut:

- Alat Pengujian: Apache JMeter
- Beban Kerja: 100 Pengguna Simultan (Concurrent Users)
- Iterasi: 10 Kali Perputaran Per Operasi
- Batas Toleransi Kinerja: Rata-rata *overhead* tambahan akibat mekanisme AAA tidak boleh melebihi batas ketat 21% dibandingkan baseline sistem sebelum AAA diimplementasikan.

6. ACCEPTANCE CRITERIA (KRITERIA PENERIMAAN)

Sistem Lost and Found IPB University dinyatakan lolos kualifikasi keamanan dan siap rilis ke lingkungan *Production* jika memenuhi seluruh kriteria berikut:

1. AC-01 (Kriptografi Kredensial): Seluruh password wajib dilewatkan pada modul hashing bcrypt dengan parameter cost ≥ 10 ; tidak ada penyimpanan teks polos.
2. AC-02 (Perlindungan Injeksi): Seluruh interaksi query basis data wajib menggunakan *Prepared Statements* atau ORM. Pengujian otomatis lewat SQLMap tidak boleh menghasilkan kebocoran data (Mitigasi SQL Injection peringkat 1).
3. AC-03 (Pemisahan Hak Akses): Mekanisme RBAC harus memblokir seluruh bypass otorisasi vertikal maupun horizontal (HTTP 403).
4. AC-04 (Keamanan Sesi & Transmisi): Token sesi harus dilengkapi flag HttpOnly, Secure, dan SameSite=Strict, serta penanganan otomatis saat token kedaluwarsa. Seluruh komunikasi wajib berjalan di atas TLS/HTTPS.
5. AC-05 (Integritas Audit Trail): Tabel log audit bersifat *append-only*. Akun database aplikasi tidak memiliki hak eksekusi instruksi UPDATE atau DELETE pada tabel log.
6. AC-06 (Ambang Batas Performa): Waktu respons rata-rata setelah implementasi AAA